Cloud Strategy and Assessment Report: Medevac Air Rescue

Executive Summary

Medevac Air Rescue is an air ambulance company providing medical repatriation, based in Paris, with 20 employees and two Challenger jets. The activity is critical and requires 24/7 availability, as missions can be triggered at 3 a.m. The company has no internal IT team. The infrastructure is ageing, and the firewall has been out of vendor support for several years. Health data is subject to strict regulatory obligations, and the annual IT budget is 30 000 euro.

The proposed solution is a hybrid cloud. Health data is hosted by a provider holding HDS certification, the French standard required for hosting health data (ANS, no date), while the remaining workloads run on the public cloud, with edge computing on board. This allocation is mandated by regulation, not chosen for technical convenience. Both environments are deployed through infrastructure as code: Terraform provides a single codebase for both, and an anomaly detection service flags suspicious access.

The expected outcomes are availability both in flight and in the office, compliance made demonstrable through traceability and certified hosting, reconstruction of the infrastructure from code after an incident, and costs contained within the annual budget, with later upgrades phased over several financial years.

Context

Medevac Air Rescue’s IT assets are 20 laptops, 20 3CX phones, one server and one NAS.

The current perimeter firewall (FortiGate 70D) reached the end of vendor support several years ago. Although it has received the latest available FortiOS updates, the hardware is ageing and has structural limitations in filtering, interconnection and traffic inspection that no longer meet current needs (Fortinet, no date). Furthermore, the geopolitical climate is driving a general increase in cyber threats, which reinforces the need to modernise both the security infrastructure and the security processes (ANSSI, 2026).

These technical limitations map directly onto operational requirements. Telephony is critical, as 3CX is the main communication tool during missions. Medical information must also be shared between the medical team in the office, the team on board and the receiving hospital, in compliance with the GDPR (European Union, 2016).

Cloud Solution Design:

Terraform deployment should start with the following modules:

1. The network:

A virtual network within the public cloud should be set up with a VPN and a firewall.

The traffic should be segmented. Indeed, the administrative traffic, medical data and access from aircraft should be separated to limit the spread of a potential cyberattack.

Network high availability is critical, as the office and on-board teams must reach each other, hospitals and families at any hour. The benefits are twofold: network security is achieved through segmentation and version-controlled rules, while cost savings come from eliminating the need to replace hardware every five years (for example, the FortiGate).

2. Network filtering module:

The network filtering module controls inbound and outbound traffic. Rules allow only the necessary flows, such as HTTPS on port 443, and block everything else by default, including insecure protocols such as HTTP on port 80.

Outbound filtering is important, since it limits data exfiltration and communication with command-and-control servers, which would have reduced the impact of an incident such as the 3CX supply-chain compromise (CISA, 2023). Because the rules are version-controlled in code, they can be reviewed and audited, unlike the rules manually accumulated on the FortiGate.

3. Identity and access:

The module creates accounts, groups, and access rules. At Medevac, profiles have different needs: medical team access patient records, whereas pilots and administrative staff do not. Access rights are therefore assigned based on roles using multi-factor authentication which limits the impact of a compromised account, the primary attack vector. Since the code defines these roles, new hires are provisioned without manual configuration or the granting of excessive rights.

4. Logging:

The logging module makes it possible to visualise and monitor the creation, modification, and destruction of resources.

For a healthcare organisation, access to patient data must also be traceable, the CNIL requires that it be possible to identify who accessed a record and when (CNIL, 2021). An unexpected change to the infrastructure can directly affect patient safety, therefore, critical modification should trigger an alert rather than simply being recorded.

Editable logs prove nothing, as an attacker can erase their tracks. The logs should be centralised outside the monitored system, in immutable storage.

Since log centralisation is billed by volume, a retention period is defined for each type. The log retention period is between 6 months and one year (CNIL, 2021).

5. Storage:

Patient data will be stored with the HDS provider, while the other data such as billing and office applications will be stored on the public cloud.

According to Article R. 1112-7 of the French Public Health Code, patients' data must be retained for 20 years, or for 10 years after the patient's death. With IaC, older or closed files can be moved to cheaper archival storage and deleted automatically once the retention period expires, while current files stay accessible in high-speed storage. The volume of records grows every year, and object storage absorbs this growth without hardware resizing, unlike the current NAS.

Soft delete and backup locking prevent an attacker from destroying the archives at the same time as the live data.



Figure 1. Storage configuration validated with terraform validate

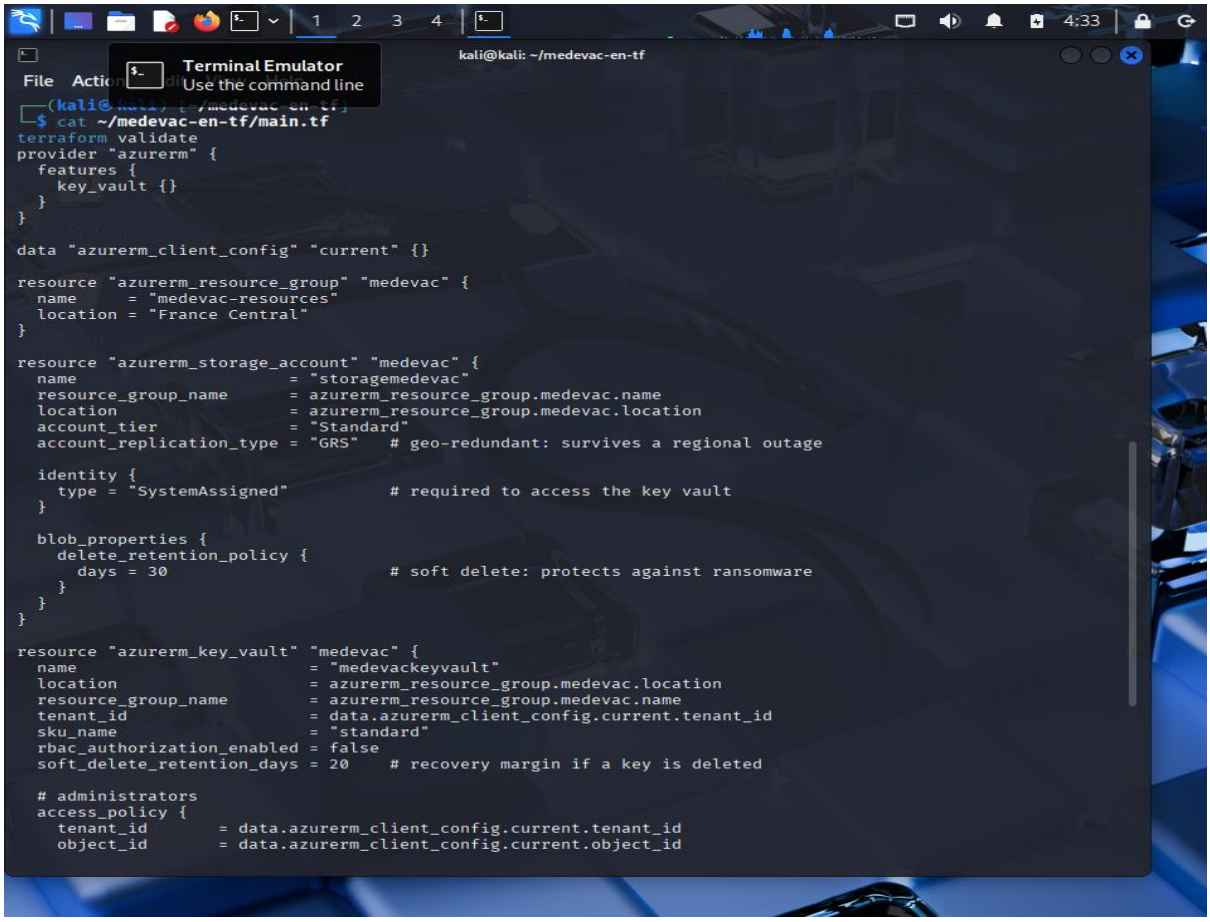
Figure 1 is adapted from the documentation for the Terraform AzureRM provider, version 5.8.0 (HashiCorp, 2026), with the replication type, soft delete and lifecycle rules added to meet Medevac's resilience and retention requirements.

The delete_retention_policy block enables soft delete, allowing 30 days to recover a file deleted either accidentally or by ransomware.

The configuration was validated without deployment, at no cost; however, validation does not confirm that a deployment would succeed.

6. Encryption:

Encryption is critical for patient data: it ensures that records remain unreadable if the storage layer is accessed by an unauthorised party.



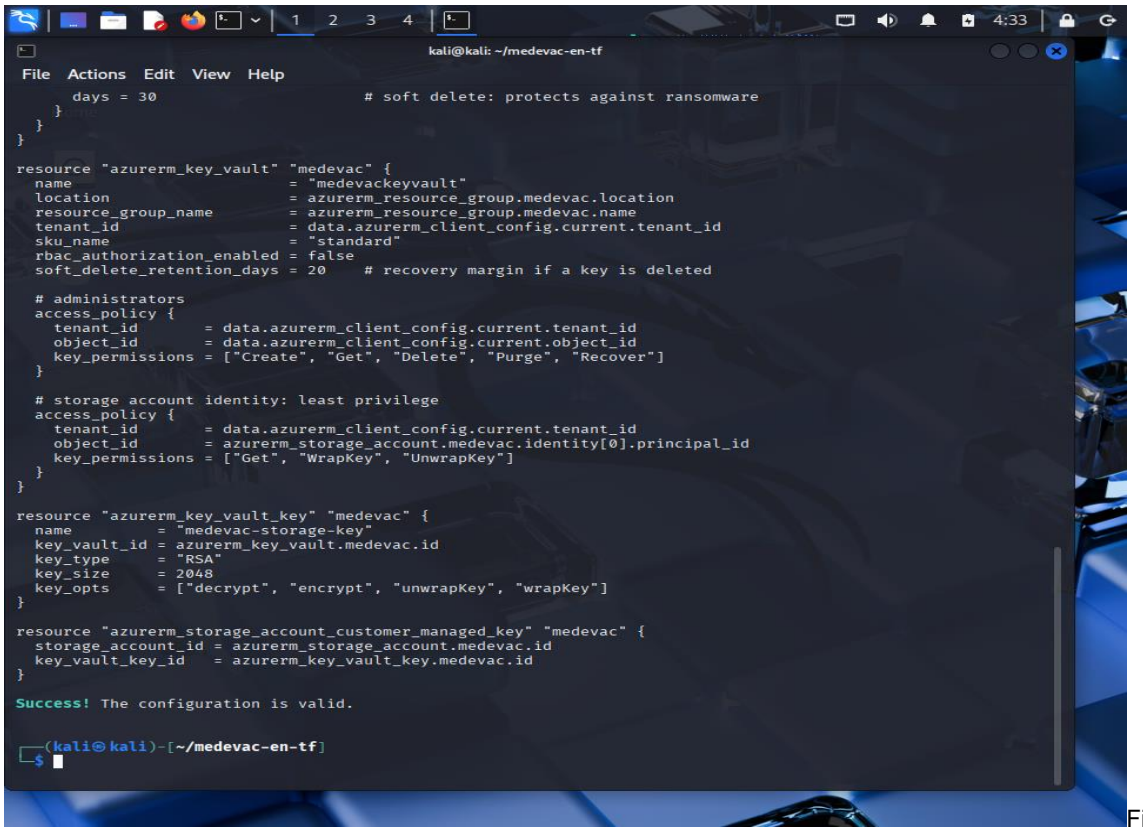


Figure 2. Encryption configuration, validated with terraform validate

Figure 2 is adapted from the documentation for azurerm_storage_account_customer_managed_key (HashiCorp, 2026).

Customer-managed key: The key belongs to Medevac, not the provider; therefore, neither the hosting provider nor a platform administrator can read the data in plaintext. Medevac controls key rotation and revocation.

Least privilege: The storage account is granted only Get, WrapKey, and UnwrapKey permissions; it is the minimum required to encrypt and decrypt without the ability to create or delete keys. Administrative rights are kept separate.

Recovery timeframes: Soft delete is set to 30 days for data and 20 days for the vault. Losing a key means permanently losing access to the data it protects; retention is therefore a measure of availability as much as security.

Geo-replication: GRS makes data survive the loss of a region, at a higher cost than local storage. This is a deliberate choice, justified by the vital nature of the activity.

Together, these choices address the three requirements: security through client-managed encryption and least privilege, resilience through geo-replication and soft delete, and cost control through the standard tier rather than hardware security modules.

The configuration shown in Figures 1 and 2 provisions the public-cloud environment; the HDS environment is provisioned separately, following the same customer-managed key principle.

7. Backup and recovery

The module provisions automated backups, defined in the code, with a retention policy aligned with legal retention requirements. Backups are stored outside the production account and are protected against deletion. This matters for Medevac because a mission can be triggered at any time; any loss of data or access must be recoverable within hours, not days.

A backup is only proven valid through a tested and verified restoration. A test might report complete success while actually covering the wrong scope. Therefore, restoration tests are scheduled and automated, and the restored content is verified.

Integration of Advanced Cloud Technologies:

Medevac is a 20-person organisation with no internal IT team. Terraform makes it possible to rebuild the infrastructure exactly as it was after an incident, without depending on a single person’s knowledge, which directly supports business continuity. The same applies to maintenance: the FortiGate went years without being replaced, and automated patching removes this dependency on human availability. Restoration testing follows the same logic, running monthly, and verifying the restored content rather than relying on a manual process that is rarely carried out.

Medevac has no SOC, and no one reviews the logs at night. Fixed rules would be ineffective here, because the activity itself is irregular: missions are triggered at any hour and from any country, so there is no normal schedule to define in advance. An anomaly detection service learns the usual patterns of each account and flags deviations, such as access to a patient record at an unusual time, or from a country

where no mission is underway. Alerts are prioritised rather than acted upon automatically: a false positive during an ongoing repatriation would be more disruptive than the threat itself, so a human decision remains required before any account is suspended.

A hybrid cloud combines private and public infrastructure while remaining managed as a single environment (Mell and Grance, 2011). HDS certification requires a qualified host for health data, but the remaining workloads, such as billing, office applications and logs, are not subject to this constraint and benefit from richer and cheaper services on the public cloud. Each type of data is placed where its legal status and its cost require it. This allocation is driven by regulatory and cost constraints, not by technical preference. The two environments are connected through an encrypted link and managed by Terraform from a single codebase, with one identity source rather than two separate directories. Data transfers between providers generate egress costs, which is why cross-environment traffic is kept to a minimum.

Edge computing moves processing close to where data is generated rather than to a central cloud (Shi et al., 2016). It is used on board because of physical constraints: in-flight satellite connections are intermittent, slow and billed by data volume. Waiting for a cloud response to display vital signs is not feasible during a medical transport. Data is therefore processed and stored locally on the device, then synchronised upon landing. The onboard unit is encrypted, as it holds health data outside the hosted environment.

Risk and Compliance Considerations:

Risk	Business impact	Probability	Mitigation measure	Residual risk after Mitigation
Ransomware	Unable to coordinate evacuation	High: The health sector is heavily targeted (ANSSI, 2026)	Soft delete, locked backups, tested restoration	Low: Restoration remains possible, but an interruption of a few hours persists
Supply chain compromise. Ex 3CX (CISA, 2023)	Loss of the mission coordination channel and a risk of data access via otherwise legitimate software	Moderate	Outbound filtering, traffic monitoring	Moderate: Filtering limits the impact, but a compromised publisher remains undetectable upstream.
Loss of availability during a mission	Inability to access patient records during	Moderate	GRS, connectivity redundancy	Low: Redundancy covers a provider's

	transport, delayed care			failure, not a failure of the in-flight satellite link.
Automation account compromise	Access to the entire environment	Low	Least privilege, secrets in a vault, strong authentication	Low: but maximum impact, so increased monitoring of this account.
AI detection false positives	Medical account locked mid-mission, leading eventually to alerts being ignored	High	Prioritised alerts, human decision-making	Moderate: Inherent to behavioural detection, reduced by adjusting thresholds, never eliminated.
Vendor lock-in	Forced cost increases, lengthy and expensive migration	High	Portable Terraform code, exportable data	Moderate: Code is portable, data less so, and managed services have

				imperfect equivalents.

Regarding compliance, health data falls under Article 9 of the GDPR (European Union, 2016) as a special category of personal data, which prohibits processing unless a specific exception applies, here, the provision of medical care. Article 32 requires measures appropriate to the risk, such as client-managed encryption, least privilege, and logging. Medevac must also maintain a record of processing activities and notify any personal data breach within 72 hours.

The HDS framework requires health data to be hosted by a certified provider, such as Claranet. The certification applies to the hosting provider and not to Medevac, which remains responsible as the data controller.

Retention periods are set out in the storage and logging modules.

The provider secures the infrastructure, while Medevac remains responsible for configuration, access management, data and GDPR compliance (European Union, 2016).

Future Recommendations:

First, post-quantum cryptography may become a significant issue. An attacker can capture encrypted data today and decrypt it later, once quantum computing makes it possible, the “harvest now, decrypt later” scenario (CISA, NSA and NIST, 2023). Since patient records are retained for 20 years, they fall within that risk window.

NIST approved the first post-quantum standards, FIPS 203, 204 and 205, in August 2024 (NIST, 2024).

The recommendation is to follow the cloud providers' migration schedules and plan the key migration, starting with a cryptographic inventory of what is encrypted and with which algorithm (CISA, NSA and NIST, 2023).

Second, edge computing can be extended. The next step is to run more advanced processing such as pre-analysing vital signs during the flight without relying on a satellite link. It is also important to address the implications; an onboard device becomes a health data collection point outside the central hosted environment, meaning it must be managed, encrypted, and capable of remote data wiping.

These developments exceed 30 000 euro per year; they are therefore spread across several financial years based on priority.

References

ANS (no date) *HDS – Certification Hébergeur de Données de Santé*. Available at: https://esante.gouv.fr/produits-et-services/hds-certification-hebergeur-de-donnees-de-sante (Accessed : 01 October 2026).

ANSSI (2026) *Panorama de la cybermenace 2025*. Available at : https://cyber.gouv.fr/nous-connaitre/publications/panoramas-de-la-cybermenace/panorama-de-la-cybermenace-2025/ (Accessed : 01October 2026).

CISA (2023) *Supply Chain Attack Against 3CXDesktopApp*. Available at: https://www.cisa.gov/news-events/alerts/2023/03/30/supply-chain-attack-against-3cxdesktopapp (Accessed: 01October 2026).

CNIL (2021) *Délibération n° 2021-122 du 14 octobre 2021 portant adoption d'une recommandation relative à la journalisation*. Available at : https://www.cnil.fr/fr/node/9999 (Accessed : 01October 2026).

European Union (2016) *Regulation (EU) 2016/679 (General Data Protection Regulation)*. Available at: https://eur-lex.europa.eu/eli/reg/2016/679/oj (Accessed: 01October 2026).

Fortinet (no date) *Firewall End-of-Life*. Available at: https://www.fortinet.com/resources/cyberglossary/end-of-life-firewall (Accessed: 01 October 2026).

HashiCorp (2026) *azurerm_key_vault*. Terraform Registry. Available at: https://registry.terraform.io/providers/hashicorp/azurerm/latest/docs/resources/key_vault (Accessed: 01 October 2026).

HashiCorp (2026) *azurerm_storage_account*. Terraform Registry. Available at: https://registry.terraform.io/providers/hashicorp/azurerm/latest/docs/resources/storage_account (Accessed: 01 October 2026).

HashiCorp (2026) *azurerm_storage_account_customer_managed_key*. Terraform Registry. Available at: https://registry.terraform.io/providers/hashicorp/azurerm/latest/docs/resources/storage_account_customer_managed_key (Accessed: 02 October 2026).

Mell, P. and Grance, T. (2011) *The NIST Definition of Cloud Computing (SP 800-145)*. Gaithersburg: NIST. Available at: https://csrc.nist.gov/pubs/sp/800/145/final (Accessed: 01 October 2026).

NIST (2024) *Announcing Approval of Three Federal Information Processing Standards (FIPS) for Post-Quantum Cryptography*. Available at: https://www.nist.gov/news-events/news/2024/08/announcing-approval-three-federal-information-processing-standards-fips (Accessed: 01 October 2026).

Public Health Code, Article R. 1112-7 (2018). Available at: https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000036658351 (Accessed: 01 October 2026)

Shi, W., Cao, J., Zhang, Q., Li, Y. and Xu, L. (2016) 'Edge Computing: Vision and Challenges', *IEEE Internet of Things Journal*, 3(5), pp. 637–646. Available at: https://ieeexplore.ieee.org/document/7488250 (Accessed:10 October 2026)